

A data protection officer (DPO) ensures within an organization that the laws protecting individuals' personal data are implemented. The designation, position and tasks of a DPO within an organization are described in Articles 37, 38 and 39 of the European Union (EU) General Data Protection Regulation (GDPR). Many other countries require the appointment of a DPO, and it is becoming more prevalent in privacy legislation. The ability of a DPO to operate independently is considered to be "of utmost importance".

According to the GDPR, the DPO should report directly to the highest management level. This does not mean that the DPO has to be directly managed at this level, but they must have direct access to give advice to senior managers who are making decisions about personal data processing.

The core responsibilities of the DPO include ensuring that his/her organization is aware of, and trained on, all relevant GDPR obligations. Common tasks of a DPO include ensuring proper processes are in place for subject access requests, data mapping, privacy impact assessments, as well as raising data privacy awareness with employees. Additionally, they must conduct audits to ensure compliance, address potential issues proactively, and act as a liaison between his/her organization and the public regarding all data privacy matters.

In Germany, a 2001 law established a requirement for a DPO in certain organizations and included various protections around the scope and tenure for the role, including protections against dismissal for bringing problems to the attention of management. Many of these concepts were incorporated into the drafting of Article 38 of the GDPR and have continued to be incorporated in other privacy standards.

References

External links

Section 4 - Data protection officer (DPO)